IS Audit & Control

Abdul-Rahman Mahmood
Assistant Professor, Computer Science, FAST-NU

abdulrahman@nu.edu.pk
alphapeeler.sf.net/pubkeys/pkey.htm
pk.linkedin.com/in/armahmood
bqb-tsid-asp
alphapeeler
alphapeeler
armahmood786
http://alphapeeler.sf.net/
reddit.com/user/alphapeeler
www.flickr.com/alphapeeler
http://alphapeeler.tumblr.com
armahmood786@jabber.org
alphapeeler@aim.com
abdulmahmood-sss
alphapeeler@icloud.com
pinterest.com/alphapeeler

Auditing Routers Switches, and Firewalls

Objectives

- Unravel the complexity of network equipment.
- Understand critical network controls.
- Review specific controls for routers, switches, and firewalls.

Background - Internet

- It started in **1962**, when Paul Baran of the RAND Corporation was commissioned by the U.S. Air Force to study how to maintain control over aircraft and nuclear weapons after a nuclear attack.
- In **1968**, ARPA (Advanced Research Projects Agency) awarded the ARPANET (Advanced Research Projects Agency Network) contract to BBN (Bolt, Beranek, and Newman).
- The physical network was constructed in **1969**, linking four nodes: the University of **California** at **Los Angeles, Stanford** Research Institute (SRI), the University of California at **Santa Barbara**, and the **University of Utah**. The network was wired together using only **50-kbps** circuits.

Background - Internet

- In 1973, development began on the protocol later termed the *Transmission Control Protocol/Internet Protocol* (TCP/IP), but it was 1977 before it was demonstrated.
- Ten years later, in **1983,** TCP/IP became the core Internet Protocol on ARPANET
- ARPANET was divided into two networks, **MILNET** and **ARPANET**. MILNET was intended to serve the needs of the military, and ARPANET was intended to support the advanced research component that later was to include commerce..

Network Auditing Essentials

- *International Standards Organization*'s (ISO) *Open System Interconnection* (OSI) model.
- **Protocols**
  - Hosts communicate with each other by first using a common language, or protocol.
- **OSI Model**
- Seven-layer OSI model describes how data moves from one system to another system.
- Two common layered models are the ISO OSI model and the TCP/IP model.

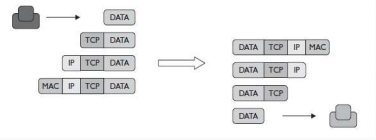
OSI Model

Layer	Common Name	Description
Layer 7	Application	Represents the end user application such as HTTP, File Transfer Protocol (FTP), Simple Mail Transport Protocol (SMTP), or Telnet.
Layer 6	Presentation	Handles formatting, encryption, compression, and presentation of data to the application. Examples include Secure Sockets Layer (SSL) and Transport Layer Security (TLS).
Layer 5	Session	Deals with the setup and management of sessions between computer applications. Examples include named pipes, NetBIOS, and session establishment for TCP.
Layer 4	Transport	Deals with transport issues, such as getting to the destination in one piece, and error control. TCP and User Datagram Protocol (UDP) are perhaps the best-known examples in this layer.
Layer 3	Network	Routes packets between networks. Examples include IP, Internet Control Message Protocol (ICMP), IP Security (IPSec), and Address Resolution Protocol (ARP). Routers operate at this layer typically using IP addresses.
Layer 2	Data Link	Links data on hosts from one location to another, typically on the local area network (LAN) but sometimes on the wide area network (WAN) too. Examples include Ethernet, Token Ring, Fiber Distributed Data Interface (FDDI), Frame Relay, and Asynchronous Transfer Mode (ATM). Switches and bridges operate at this layer, typically using Media Access Control (MAC) addresses.
Layer 1	Physical	Defines the physical link, cabling, and binary transmission. Modulation and flow control occur at this layer.

Table 5-1 Simplified OSI Model Description

Routers and Switches

- Routers connect and route data between networks using Layer 3 network addresses, usually IP addresses.
- Once data is routed to the destination network, the data goes to a switch where the destination host resides.
- Everything at the switch level typically is handled with the MAC address, represented by OSI Layer 2.



Data encapsulation

Routers and Switches

- Help segment networks and users into appropriate security zones.
- National Institute of Standards and Technology (NIST) Publication 800-41-Rev1.
- Used for perimeter protection or for creating concentric rings of various levels of trust within a network.
- Firewalls have developed into specialized functions that include protecting virtualized machines from each other on virtual networks or protecting web hosts from network attacks specifically targeting web traffic.

Packet Filtering Firewalls

- Packet filtering firewalls are essentially routers operating at **Layer 3 using set ACLs.** Decisions are made to allow and disallow traffic based on the source and destination IP address, protocol, and port number.

Layer	Name	Equipment Used	Depends on	Example
Layer 3	Network	Routers	IP Address—WAN	198.133.219.25
Layer 2	Data Link	Switches	MAC Address—LAN	00-14-22-F5-04-16

Stateful Inspection Firewalls

- *Stateful inspection*, also stateful packet inspection (SPI) or dynamic packet-filtering firewalls, operate at **Layers 3 and 4**. Your router at home allows you to establish and maintain a session externally with another address. **The "state" refers to identifying and tracking sessions that occur in Layers 4 (transport) and 5 (session)** . The rules are changed dynamically when you establish an outbound connection to enable packets from the destination IP address to be returned to you. All other **traffic is stopped from reaching your computer,** protecting you from the dangers inherent in the Internet.

Application Firewalls

- Application-level firewalls combine the functionality of the typical firewall operating in the lower OSI layers with the power and deep inspection of **application awareness**.
- Now, based on **information at the application level,** such as known malicious traffic, decisions can be made to allow or disallow traffic. An example might be an appliance or **host that screens web traffic before it hits your web server**. Based on the behavior and content of the web traffic, decisions might be made dynamically to refuse access to the web server.

Application-Proxy Gateway

- Application-proxy gateways manage conversations between hosts, acting as an intermediary at the application level of the OSI model. Because proxies reestablish conversations to the destination, they effectively can hide the source of a conversation. Proxies might enforce authentication, logging, or content rules. One of the advantages of application-proxy gateways is the potential ability to **stop an encrypted session, decode the data, read the data in clear-text, encode the data, and then reinitiate an encrypted session to the destination**. This is extremely resource-intensive and performance requirements become a concern for these applications.

Additional Firewall Technologies

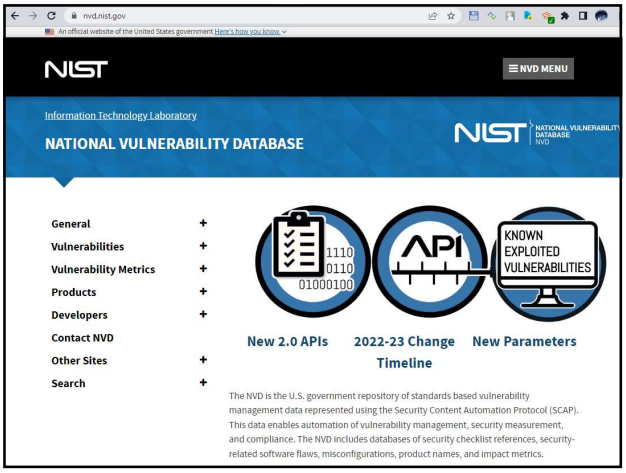
- NIST Publication 800-41-Rev1 :
  - Dedicated Proxy Servers,
  - Virtual Private Networking,
  - Network Access Control,
  - Unified Threat Management,
  - Web Application Firewalls,
  - and Firewalls for Virtual Infrastructures.
- NIST Publication 800-41-Rev1, "Guidelines on Firewalls and Firewall Policy," can be found at http://csrc.nist.gov/publications/PubsSPs.html.

General Network Equipment Audit Steps

- 1. Review controls around developing and maintaining configurations.
  - Ensure monitoring of **security mailing lists**.
  - **Patches** are applied under the guidance of written and agreed-on policies.
  - A **configuration guideline** exists for the equipment.
  - Regular **vulnerability scanning** from both internal and external perspectives is conducted.
  - Regular **internal reviews** of the configuration are conducted.
  - Regular **status reports** are issued to upper management.

General Network Equipment Audit Steps

- 2. Ensure that appropriate controls are in place for any **vulnerabilities** associated with the current software version. These controls might include software updates, configuration changes, or other compensating controls.
  - NVD : http://nvd.nist.gov



General Network Equipment Audit Steps

- 3. Verify that all unnecessary services are disabled.
  - Refer to the **vendor** for the required services and those that might be considered security risks.

See Lecture Notes:

How to Stop and Disable Unwanted Services from Linux System

What Windows 11 Services to Disable Safely and How

General Network Equipment Audit Steps

- 4. Ensure that good SNMP management practices are followed.
  - SNMP V1 and V2 sends community string in clear text.
  - SNMP V3 adds message integrity, authentication, and encryption to the packets.
  - SNMP community strings should follow standard password policies for strength and change frequency.
  - Management with SNMP should be restricted with an access list, and no management should be allowed from an untrusted network.
  - Refer to CISCO guidelines.

SNMP community strings 1

- Grant read-only access to all clients. With the following configuration, the system responds to SNMP Get, GetNext, and GetBulk requests that contain the community string public:

```
snmp {
        community public {
        authorization read-only;
        }
}
```

SNMP community strings 2

- Grant all clients read-write access to the ping MIB and jnxPingMIB. With the following configuration, the system responds to SNMP Get, GetNext, GetBulk, and Set requests that contain the community string private and specify an OID contained in the ping MIB or jnxPingMIB hierarchy:

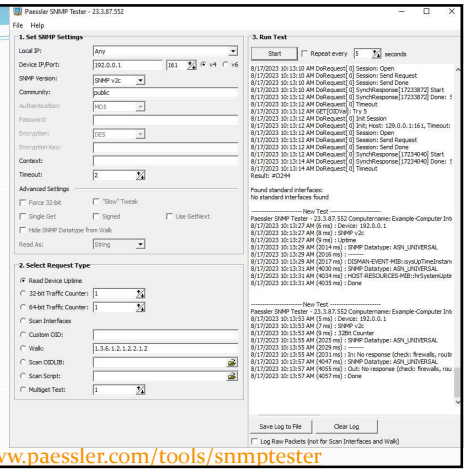
```
snmp {
        view ping-mib-view {
                oid pingMIB include;
                oid jnxPingMIB include;
                        community private {
                                authorization read-write;
                                view ping-mib-view;
                        }
                }
}
```

SNMP community strings 3

- The following configuration allows read-only access to clients with IP addresses in the range 1.2.3.4/24, and denies access to systems in the range fe80::1:2:3:4/64:

```
snmp {
        community field-service {
                authorization read-only;
                clients {
                        default restrict;
                        1.2.3.4/24; # Allow access by all clients in
                                1.2.3.4/24 except
                        fe80::1:2:3:4/64 restrict;
                        # fe80::1:2:3:4/64 is not allowed
                }
        }
}
```

SNMP Tester



- https://www.paessler.com/tools/snmptester

General Network Equipment Audit Steps

- 5. Review procedures for creating user accounts & ensuring that accounts are created only when there's a legitimate need. Accounts should be removed or disabled in a timely fashion.
  - Obtain a sample of accounts, and verify that they are owned by active employees and that those employees' job positions have not changed since the account's creation.
  - Accounts should never be shared among administrators.
  - individual IDs should be created for every user requiring access to the network device
  - Network device should use a central authentication server for user accounts (*AAA server, e.g, RADIUS, TACACS).*

TACACS+ config issues

- Some network infrastructures may use TACACS+ for AAA on routers and switches. It allows anyone with a Remote Access Services (RAS)
  - Solution: enabled NT account to log onto the router in nonprivileged mode. An additional "enable" password is then required for privileged access. An example
- Individual IDs might look something like this in the configuration file:
  `username <name> password 7 <encrypted password>`
  - CISCO Type 7 passwords use a very weak algorithm that can be easily reversed
  - Cisco Type 7 Password Decrypt / Decoder / Crack Tool https://www.firewall.cx/cisco/cisco-routers/cisco-type7-password-crack.html
  - Solution: These IDs should be created with a privilege level of 1 (which is the default), forcing the enable password to be required for additional access.

TACACS Installation

- The following command will install the tac-plus service:
- #apt-get install tac-plus
  /usr/sbin/tac_plus -C /etc/tac-plus/tacacs.conf -d 16
- The following command shows debugging information of the tac-plus service
  tail -f /var/tmp/tac-plus.log
- to kill....
  kill -USR1 `cat /etc/tac-plus.pid`
- To restart...
  /etc/init.d/tac-plus restart

TACACS Files

- **Files**
  /var/log/tac-plus/account.log (must make this file writable)
  /var/tmp/tac_plus.log (service logfile)
  /etc/init.d/tac-plus (startup script)
  /etc/tac-plus/tacacs.conf (users and global settings)
  /usr/sbin/tac_plus (executable)

  create des encrypted password: htpasswd -n debianhelp

Server Config file (/etc/tac-plus/tacacs.conf)

```
#This user can do anything
user = admins {
    default service = permit
    login = des 70e4lCVGyWSKM
}
#this user can only run 'show ip' and
'show interface'
user = users {
    default service = deny
    login = cleartext test
        cmd = show
                {
                permit ip
                permit interface
                deny .*
                }
}
```